authentication context to the other system applications? This chapter will help you solve that problem using OAuth2 and Access Tokens.

After dealing with authentication, we will address the authorization step. Right now, both customers and employees of Polar Bookshop can perform any action on the system. This chapter will walk you through a few authorization scenarios handled with OAuth2, Spring Security, and Spring Data:

- We'll use a role-based access control (RBAC) strategy to protect the REST endpoints exposed by Spring Boot, depending on whether the user is a customer or an employee of the bookshop.
- We'll configure data auditing to keep track of which user made what changes.
- We'll enforce protection rules for data so that only its owner can access it.

Finally, you'll explore how you can test those changes using Spring Boot, Spring Security, and Testcontainers.

NOTE The source code for the examples in this chapter is available in the Chapter12/12-begin and Chapter12/12-end folders, containing the initial and final states of the project (https://github.com/ThomasVitale/cloud-native-spring-in-action).

12.1 Authorization and roles with Spring Cloud Gateway and OAuth2

In the previous chapter, we added user authentication features to Polar Bookshop. Edge Service is the access point to the system, so it's an excellent candidate for addressing cross-cutting concerns like security. For that reason, we made it responsible for authenticating users. Edge Service initiates the